

**PENANGANAN INSIDEN
SOCIAL ENGINEERING
(Phishing, Vishing, Smishing)**

CYBER SECURITY SOLUTION GUIDE



Versi 1.0

February.....2026

**DIGITAL HEALTHCARE
IT OPERATION**

Daftar Isi

Riwayat Dokumen	ii
Lembar Pemeriksaan Kecukupan Dokumen	ii
Definisi	iii
1. Latar Belakang.....	1
2. Maksud & Tujuan	1
2.1 Maksud.....	1
2.2 Tujuan.....	1
3. Ruang Lingkup	2
4. Tahapan Penanganan Insiden Rekayasa Sosial (Phising, Vishing, Smishing)	3
4.1 Persiapan	4
4.2 Deteksi & Analisis	5
4.3 Penahanan, Pembersihan & Pemulihan	6
4.3.1 Penahanan	6
4.3.2 Pembersihan	7
4.3.3 Pemulihan	8
4.4 Dokumentasi Insiden	9
Referensi	10
Lampiran	11

Riwayat Dokumen

No	Tanggal	Versi	Penulis	Unit	Keterangan
1	23 Februari 2026	1.0	Aldila Nur Azizah	<i>Digital Healthcare & IT Operation</i>	

Lembar Pemeriksaan Kecukupan Dokumen

	NAMA / NIK	JABATAN	TTD
Dibuat oleh	Aldila Nur Azizah/3202005	<i>Internship</i>	
Diperiksa oleh			
Disetujui oleh			

Definisi

- a. **Containment (Penahanan):** Langkah darurat untuk "mengunci" atau membatasi area yang terserang agar kerusakan tidak menyebar ke bagian lain dalam organisasi.
- b. **DMARC/SPF/DKIM:** Protokol keamanan email yang berfungsi sebagai "stempel resmi" untuk memastikan bahwa email yang masuk benar-benar berasal dari pengirim asli, bukan dari penipu yang memalsukan nama instansi.
- c. **DNS Sinkholing:** Teknik mengarahkan permintaan akses ke situs berbahaya menuju sebuah "lubang pembuangan" (server buntu), sehingga perangkat karyawan tidak akan pernah bisa terhubung ke situs penipuan tersebut meskipun tautannya diklik.
- d. **Endpoint Detection and Response (EDR):** Alat keamanan yang dipasang di setiap komputer atau laptop karyawan untuk memantau aktivitas mencurigakan secara mendalam dan mampu melakukan tindakan darurat seperti mengisolasi komputer dari jaringan jika terinfeksi.
- e. **FIDO2 / Hardware Token:** Teknologi keamanan kunci fisik (seperti USB khusus) yang digunakan sebagai alat masuk akun. Ini jauh lebih aman daripada kode SMS karena kunci ini tidak bisa dipalsukan oleh penipu.
- f. **Forwarding Rules (Aturan Penerusan):** Pengaturan otomatis di email yang bisa disalahgunakan penyerang untuk mengirimkan setiap salinan email masuk milik korban ke alamat email milik penyerang secara diam-diam.
- g. **Indikator Kompromi (IOC):** Serangkaian bukti teknis (seperti alamat situs palsu, nama file berbahaya, atau alamat email pengirim) yang menunjukkan bahwa sebuah serangan sedang atau telah terjadi.
- h. **Indicator of Attack (IOA):** Serangkaian tanda yang menunjukkan bahwa sebuah serangan sedang berlangsung. Jika IOC adalah bukti setelah kejadian, IOA adalah pola perilaku mencurigakan (seperti percobaan login berkali-kali secara cepat) yang terpantau saat penyerang sedang mencoba masuk.
- i. **Link Rewriting & Sandboxing:**
 - **Link Rewriting:** Mengubah alamat tautan dalam email agar setiap kali diklik, sistem keamanan akan memeriksa dulu keamanannya.
 - **Sandboxing:** Teknik menjalankan lampiran email di "ruang isolasi" virtual yang aman untuk melihat apakah lampiran tersebut mengandung virus sebelum benar-benar dibuka oleh pengguna.
- j. **Malware:** Singkatan dari *Malicious Software*, yaitu program jahat (seperti virus) yang dirancang untuk merusak sistem, mencuri data, atau memata-matai aktivitas pengguna.
- k. **MITRE ATT&CK:** Sebuah basis data atau kamus besar yang mencatat semua taktik dan cara yang biasa digunakan oleh penjahat siber di seluruh dunia, digunakan sebagai referensi tim keamanan untuk mengenali pola serangan.
- l. **Multi-Factor Authentication (MFA):** Fitur keamanan ganda yang mengharuskan pengguna memasukkan lebih dari sekadar kata sandi untuk masuk ke akun (misalnya kode SMS atau sidik jari).
- m. **Phishing:** Penipuan melalui email palsu yang menyamar sebagai instansi resmi untuk mencuri data pribadi (seperti username dan password).
- n. **Secure Email Gateway (SEG) :** Sistem penyaring email yang bertindak sebagai "satpam" di gerbang depan. Tugasnya memeriksa setiap email yang masuk untuk memblokir virus, link berbahaya, atau email penipuan sebelum sampai ke kotak masuk karyawan.

- o. **Security Information and Event Management (SIEM)** : Sebuah sistem pusat yang berfungsi sebagai "kotak hitam" atau pengawas digital yang mengumpulkan dan menganalisa semua catatan aktivitas (log) dari seluruh perangkat IT untuk mendeteksi tanda-tanda serangan secara otomatis.
- p. **Sinkholing**: Teknik keamanan untuk mengalihkan lalu lintas internet dari situs berbahaya (palsu) ke server aman, sehingga korban tidak bisa mengakses situs penipuan tersebut.
- q. **Smishing**: Singkatan dari SMS Phishing, yaitu penipuan rekayasa sosial yang dikirimkan melalui pesan teks (SMS) atau aplikasi pesan singkat seperti WhatsApp.
- r. **Social Engineering (Rekayasa Sosial)**: Teknik penipuan yang tidak menyerang sistem komputer secara langsung, melainkan memanipulasi psikologis manusia agar korban membocorkan rahasia atau melakukan kesalahan yang menguntungkan penyerang.
- s. **Typosquatting**: Taktik penipuan dengan membuat nama domain atau alamat situs yang sangat mirip dengan aslinya namun ada sedikit salah ketik (misal: yakes-telkom.co.id menggunakan huruf 'i' besar untuk mengganti huruf 'l'), bertujuan agar pengguna tidak sadar sedang berada di situs palsu.
- t. **Vishing**: Singkatan dari Voice Phishing, yaitu penipuan melalui telepon atau pesan suara, seringkali menggunakan teknologi *Voice Cloning* (peniruan suara) untuk meyakinkan korban.

1. Latar Belakang

Di tengah akselerasi transformasi digital, ancaman siber tidak lagi hanya menyerang kerentanan sistem teknis, tetapi juga menargetkan kerentanan manusia sebagai rantai terlemah dalam keamanan. Rekayasa sosial telah berkembang menjadi metode serangan yang sangat efektif karena memanfaatkan manipulasi psikologis—seperti rasa takut, urgensi, atau keinginan untuk membantu—untuk mendapatkan akses ilegal ke informasi sensitif.

Munculnya berbagai varian serangan seperti **Phishing** melalui email, **Smishing** melalui pesan teks, hingga **Vishing** yang menggunakan teknologi *Voice Cloning*, menuntut adanya prosedur penanganan yang terstandarisasi. Tanpa adanya panduan yang sistematis, kecepatan respons terhadap insiden akan terhambat, yang berisiko pada kebocoran data kredensial, infeksi malware, hingga kerugian finansial yang signifikan bagi organisasi dan individu.

Oleh karena itu, diperlukan integrasi teknologi keamanan seperti *Email Gateway*, SIEM, dan EDR ke dalam satu alur kerja yang terstandarisasi. Melalui *playbook* ini, tim SOC dan Insiden Respon memiliki pedoman yang rinci untuk bertindak secara konsisten, cepat, dan akurat. Dan juga sebagai bahan evaluasi dan edukasi berkelanjutan guna memastikan seluruh ekosistem digital organisasi tetap tangguh dan aman dari ancaman di masa depan.

2. Maksud & Tujuan

2.1 Maksud

Penyusunan *playbook* ini dimaksudkan sebagai pedoman operasional bagi tim *Security Operations Center* (SOC) dan Insiden Respon (IR) dalam menghadapi serangan berbasis rekayasa sosial. Dokumen ini menyediakan langkah-langkah teknis dan administratif yang konsisten untuk memastikan setiap deteksi serangan dapat direspon dengan cara yang sama.

2.2 Tujuan

1. Deteksi Dini dan Akurat:
Mengidentifikasi indikator serangan (*IOC/IOA*) secara cepat sebelum terjadi kebocoran data yang meluas.
2. Mitigasi dan Penahanan Efektif:
Menghentikan penyebaran pesan berbahaya dan membatasi akses pada akun atau perangkat yang telah terkompromi.
3. Pemulihan Kepercayaan:
Mengembalikan integritas sistem dan akun pengguna secara aman serta memberikan edukasi agar pengguna tidak kembali menjadi korban di masa depan.
4. Standarisasi Dokumentasi:
Memastikan setiap tahapan insiden tercatat dengan baik untuk kepentingan analisis forensik dan pembelajaran berkelanjutan organisasi.

3. Ruang Lingkup

Playbook ini berlaku untuk seluruh lingkungan *Digital Healthcare IT Operation* yang mencakup sistem, perangkat, serta pengguna yang berpotensi menjadi target serangan berbasis rekayasa sosial.

Ruang lingkup playbook ini meliputi:

1. Sistem email organisasi dan SEG.
2. Infrastruktur keamanan email (DMARC, SPF, DKIM)
3. Sistem autentikasi dan manajemen identitas (*Active Directory*, MFA, FIDO2/*Hardware Token*)
4. Endpoint pengguna (Laptop, PC, dan perangkat kerja lainnya)
5. Sistem keamanan jaringan seperti Firewall, Web Proxy, DNS Filtering, dan IDS/IPS
6. Sistem monitoring dan logging seperti SIEM dan EDR

Playbook ini digunakan khusus untuk menangani insiden yang disebabkan oleh serangan Social Engineering yang meliputi:

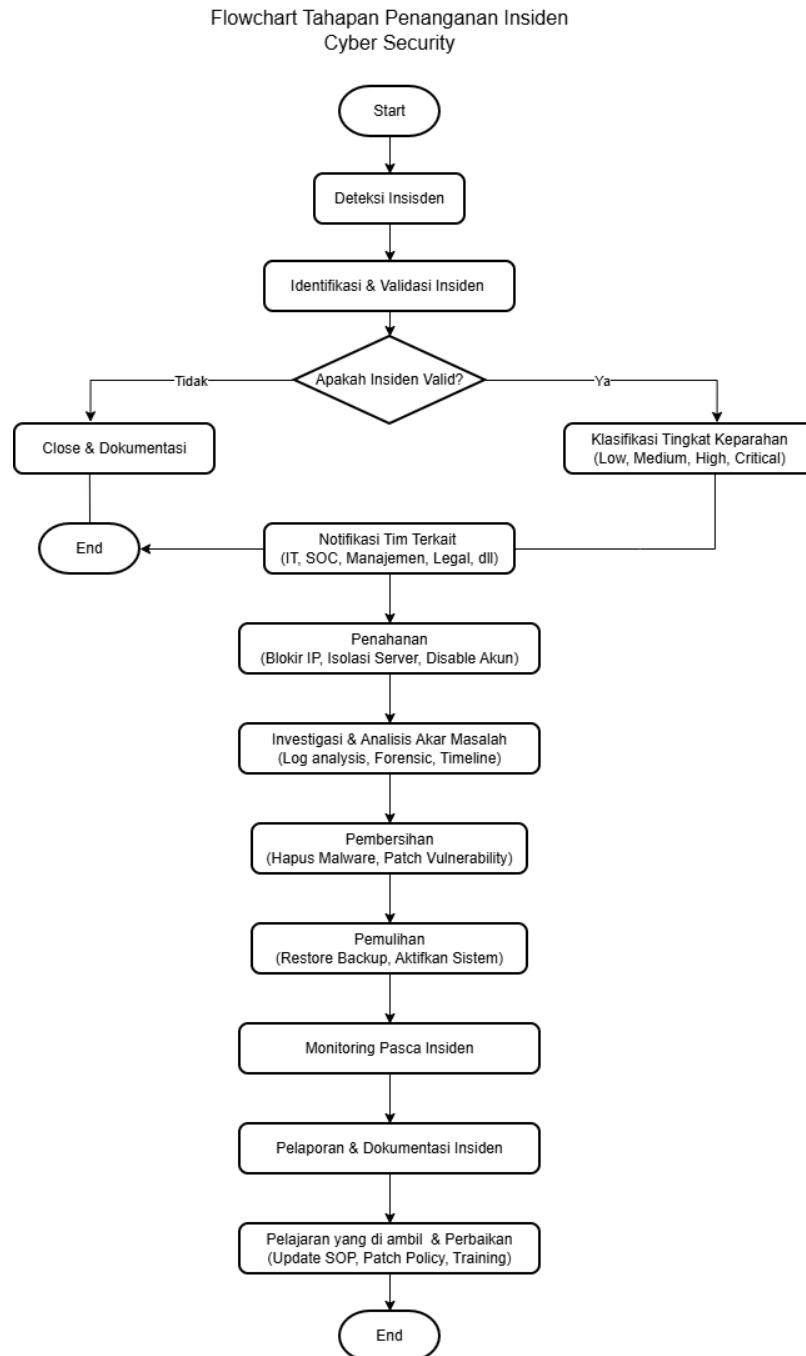
1. Phishing melalui email
2. Smishing melalui SMS atau aplikasi pesan instan
3. Vishing melalui panggilan telepon atau pesan suara

Playbook ini mencakup proses penanganan mulai dari tahap persiapan deteksi dan analisis, penahanan, pembersihan, pemulihan, hingga aktivitas pasca insiden.

Playbook ini tidak mencakup penanganan insiden teknis murni seperti serangan Denial-of-Service, eksploitasi celah jaringan, atau penyebaran worm, kecuali insiden tersebut diawali atau dipicu oleh teknik rekayasa sosial.

4. Tahapan Penanganan Insiden Rekayasa Sosial (Phising, Vishing, Smishing)

Setiap indikasi serangan rekayasa sosial (*Social Engineering*) seperti *Phishing*, *Vishing*, maupun *Smishing* harus ditangani melalui serangkaian proses standar untuk memastikan respons yang cepat dan akurat. Alur ini berfungsi sebagai panduan bagi tim keamanan dalam memvalidasi setiap temuan, menentukan skala prioritas berdasarkan tingkat risiko, hingga melakukan pendokumentasian akhir untuk mencegah kejadian serupa di masa depan. Berikut adalah visualisasi Flowchart Tahapan Penanganan Insiden :



4.1 Persiapan

adalah fase awal dan paling krusial dalam siklus penanganan insiden yang berfokus pada pembangunan fondasi pertahanan dengan tujuan untuk menyiapkan seluruh perangkat teknis, kebijakan operasional, serta kesiapan sumber daya manusia sebelum serangan benar-benar terjadi

Kategori	Detail
Kesiapan Alat Deteksi	- Konfigurasi <i>Email Gateway</i> (SEG) untuk melakukan <i>Link Rewriting</i> dan <i>Sandboxing</i>. - Integrasi log ke SIEM dan pembuatan aturan korelasi untuk deteksi login tidak wajar. - Aktivasi EDR pada <i>endpoint</i> untuk memantau aktivitas browser yang mencurigakan.
Kebijakan & Protokol	- Implementasi autentikasi email yang ketat menggunakan DMARC, SPF, dan DKIM. * Penerapan <i>MFA Enforcement</i> (FIDO2/Hardware Token) secara menyeluruh. - Penetapan <i>Callback Policy</i> sebagai prosedur verifikasi pihak ketiga untuk mencegah <i>Vishing</i>.
Kesiapan SDM	- Penyelenggaraan <i>Targeted Awareness Training</i> mengenai bahaya rekayasa sosial. - Sosialisasi penggunaan <i>Report Phishing Button</i> untuk memudahkan laporan pengguna. - Pembentukan <i>program Security Champions</i> untuk memperkuat budaya keamanan di setiap unit.
Simulasi & Pengujian	- Pelaksanaan Simulasi Phishing Berkala untuk menguji kewaspadaan karyawan. - Latihan <i>Vishing Tabletop Exercise</i> dan <i>Red Team Social Engineering Drill</i> untuk kesiapan tim IR.

4.2 Deteksi & Analisis

Adalah fase operasional untuk mengidentifikasi aktivitas mencurigakan dan melakukan analisis mendalam guna mengonfirmasi sebuah insiden. Tahap ini bertujuan untuk memvalidasi laporan, menentukan jenis serangan (*Phishing*, *Smishing*, atau *Vishing*), serta mengukur tingkat keparahan dampak sebelum tindakan penanganan dilakukan

Kategori	Detail
Sumber Log	Email Gateway (SEG), Web Proxy, DNS Logs, SIEM, dan Laporan Pengguna (User Report)
Indikator IOC (Indikator Kompromi)	- Alamat pengirim palsu (<i>typosquatting</i>). - URL/Domain mencurigakan atau baru terdaftar. - Hash lampiran berbahaya (.html, .zip, .exe). - Nomor telepon/ID pengirim tidak dikenal (Smishing/Vishing).
Indikator IOA (Indikator Serangan)	- Akses masif ke URL yang sama oleh banyak user. - Percobaan login dari lokasi tidak biasa setelah menerima pesan. - Permintaan data sensitif mendadak melalui telepon (Vishing)
MITRE ATT&CK	T1566 (Phishing), T1566.003 (Spearphishing), T1598 (Social Engineering)
Aturan SIEM Wazjib	- Alert pengirim eksternal menggunakan nama tampilan internal. - Korelasi klik link diikuti perubahan password akun atau kegagalan login massal.
Deteksi EDR	Aktivitas browser tidak wajar atau eksekusi perintah (PowerShell/CMD) dari lampiran pesan
Deteksi Firewall / IDS	Koneksi keluar ke domain phishing yang sudah masuk daftar blokir
Aksi SOC Saat Terdeteksi	- Validasi laporan - tentukan tingkat keparahan, dan - eskalasi ke tim IR

4.3 Penahanan, Pembersihan & Pemulihan

4.3.1 Penahanan

adalah fase kritis yang bertujuan untuk membatasi ruang gerak penyerang dan menghentikan penyebaran ancaman sesegera mungkin. Fokus utama tahap ini adalah mengisolasi sistem atau akun yang terdampak agar kerusakan tidak meluas seperti memutus akses ke tautan berbahaya atau mencabut sesi login yang telah terkompromi

Kategori	Detail
Langkah Utama	- <i>Search & Purge</i>: Hapus pesan/email berbahaya dari seluruh kotak masuk sistem. - Cabut sesi login aktif (<i>Revoke Session Tokens</i>) pada akun terdampak.
Tindakan Jaringan	- <i>Blokir</i> domain/URL dan IP pengirim pada Firewall dan Web Proxy. - <i>Sinkhole</i> domain phishing pada DNS internal.
Tindakan Endpoint	Isolasi perangkat (<i>Isolate Host</i>) jika pengguna terlanjur mengunduh atau menjalankan lampiran.
Tindakan Akses	- Nonaktifkan akun (<i>Disable Account</i>) yang terindikasi membocorkan kredensial. - Blok user mencurigakan
Kriteria Containment Berhasil	Penyebaran pesan berhenti, link tidak dapat diakses, dan akun korban telah diamankan

4.3.2 Pembersihan

Adalah fase untuk menghilangkan akar penyebab serangan secara permanen serta menghapus sisa-sisa komponen berbahaya (seperti malware atau skrip), menutup celah akses yang dibuat penyerang (seperti *backdoor* atau aturan penerusan email)

Kategori	Detail
Identifikasi Root Cause	Analisis metode masuk: Phishing (Email), Vishing (Suara), atau Smishing (SMS/WA).
Penghapusan Komponen Malware	- Hapus file unduhan, dropper, atau script berbahaya dari perangkat korban.
Penghapusan Persistensi	Periksa dan hapus aturan penerusan email otomatis (<i>Forwarding Rules</i>) yang tidak sah
Penghapusan Backdoor	Cabut izin aplikasi pihak ketiga (OAuth) mencurigakan yang diberi akses oleh user
Reset Kredensial	Reset password akun terkait dan perbarui rahasia/metode MFA
Patch / Perbaikan	Perbarui filter pada <i>Email Gateway</i> dan perketat kebijakan keamanan web.
Pemindaian Sistem	Lakukan <i>Full Scan</i> menggunakan EDR/Antivirus pada endpoint yang terpapar.
Validasi Bersih	Pastikan tidak ada aktivitas login ilegal atau koneksi keluar mencurigakan

4.3.3 Pemulihan

Adalah fase mengembalikan sistem dan layanan yang terdampak ke kondisi operasi normal secara aman. Fokus utamanya adalah memastikan bahwa sistem yang dipulihkan sudah bersih dari ancaman, memverifikasi integritas akun pengguna, serta melakukan pemantauan ketat untuk mencegah terjadinya infeksi ulang (*re-infection*).

Kategori	Detail
Pemulihan Data	Pulihkan email penting yang mungkin terhapus selama proses pembersihan massal.
Rebuild Sistem	Install ulang OS jika ditemukan malware jenis <i>infostealer</i> atau <i>keylogger</i> yang berat.
Validasi Sistem	Pastikan user dapat kembali bekerja dengan kredensial baru secara aman.
Sertifikasi Keamanan	Audit ulang hak akses akun yang sempat kompromi (Privilege review).
Monitoring Lanjutan	Pemantauan ketat log login dan audit trail selama 14–30 hari.
Edukasi Pengguna	Wajib: Memberikan pelatihan khusus mengenai teknik Social Engineering kepada korban.

4.4 Dokumentasi Insiden

Dokumentasi insiden adalah proses pencatatan secara sistematis seluruh informasi yang berkaitan dengan kejadian serangan *Social Engineering (Phishing, Smishing, Vishing)*, mulai dari pertama kali terdeteksi hingga proses pemulihan dinyatakan selesai. Dokumentasi ini memastikan bahwa seluruh tindakan, bukti teknis, analisis, serta keputusan selama penanganan insiden tercatat dengan jelas, terdokumentasi dengan baik, dan dapat dipertanggungjawabkan untuk keperluan audit, forensik, maupun evaluasi internal.

Kategori Data	Detail Informasi
Informasi Wajib	1. Jenis serangan (Phishing Email / Smishing SMS/WA / Vishing Telepon). 2. Identitas insiden dan tingkat keparahan (Low / Medium / High). 3. Target serangan (akun email, nomor telepon, departemen terdampak). 4. Jumlah pengguna yang menerima pesan dan yang berinteraksi (klik link / isi kredensial / unduh file). 5. Waktu pertama terdeteksi, waktu penanganan, dan waktu pemulihan selesai (timeline lengkap). 6. Dampak insiden (kebocoran kredensial, malware terinstal, akses tidak sah, atau tidak ada dampak signifikan).
Bukti Forensik	1. Salinan email/SMS/rekaman panggilan yang digunakan dalam serangan. 2. Header email lengkap (untuk analisis pengirim asli dan hasil SPF/DKIM/DMARC). 3. Daftar URL/domain phishing, alamat IP terkait, serta hasil analisis WHOIS/domain age jika relevan. 4. Hash file lampiran berbahaya (.html, .zip, .exe, .pdf). 5. Log dari SEG, SIEM, Web Proxy, DNS, dan EDR terkait aktivitas korban. 6. Bukti aktivitas mencurigakan (percobaan login tidak wajar, perubahan password, pembuatan forwarding rules, OAuth mencurigakan)
Tindakan Diambil	1. Search & Purge email berbahaya dari seluruh mailbox. 2. Pemblokiran domain/URL/IP pada Firewall, Web Proxy, dan DNS Filtering (termasuk sinkhole jika diterapkan). 3. Revoke session login aktif dan reset password akun terdampak. 4. Isolasi endpoint dan full scan EDR jika terdapat indikasi malware. 5. Penghapusan forwarding rules dan pencabutan akses OAuth/aplikasi pihak ketiga mencurigakan. 6. Edukasi ulang pengguna serta monitoring lanjutan 14–30 hari

Referensi

- cyber-security-threats*. (n.d.). Retrieved from <https://www.imperva.com/>:
<https://www.imperva.com/learn/application-security/cyber-security-threats/>
- group, i. r. (2024, March 15). <https://www.incidentresponse.com/minisites/playbooks/phishing>. Retrieved from incidentresponse:
<https://www.incidentresponse.com/>
- MP, A. (2025, Agustus 21). *incidentresponse*. Retrieved from
<https://www.arrezamp.com/>: <https://www.arrezamp.com/>
- online, C. c. (n.d.). *what is incident response*. Retrieved from
<https://online.champlain.edu/>: <https://online.champlain.edu/blog/what-incident-response>

Lampiran

FORM LAPORAN INSIDEN PHISHING, SMISHING, VISHING

Judul insiden :

Tempat & Waktu :

Tim CSIRT :

Sistem Terdampak :

.....
.....

Ringkasan Insiden :

.....
.....

Kronologi :

.....
.....

Akar Masalah (Root Cause) :

.....
.....

Indikator (IOC / IOA) :

- Hash :

- Ip/Domain :

- Port :

Analisis Teknis :

.....
.....

Aksi SOC (Detection) :

.....
.....

Aksi IR (Response) :

.....
.....

Pemulihan :

.....
.....

Rekomendasi :